

# Cyber Tabletop Exercise

## Core Banking Vendor Compromise

Revised facilitation-ready package - third-party core banking SaaS software update-channel compromise

|                      |                                                                                                                |
|----------------------|----------------------------------------------------------------------------------------------------------------|
| Scenario source      | Uploaded source TTX and evaluation feedback; derived from STIX-style third-party core banking SaaS compromise  |
| Classification       | Internal use for exercise purposes only                                                                        |
| Recommended duration | 90 minutes; compressed 75-minute version possible by reducing debrief depth                                    |
| Audience             | Executive, operational, technical, legal/compliance, communications, third-party risk, business continuity     |
| Exercise type        | Discussion-based tabletop exercise with phased injects, evidence cards, decision points, and facilitator notes |

### Facilitator note

This revised version preserves the original scenario structure while adding concrete architecture, bank-side observables, defined vendor evidence, realistic isolation/reconnection gates, and evidence-backed ATT&CK mapping.

Prepared for live exercise facilitation. Replace generic bank/vendor names, severity labels, contact names, and jurisdictional notification references with local details before delivery.

## 0. Contents

- 1. Exercise Overview
- 2. Background Context
- 3. Exercise Objectives
- 4. Scope
- 5. Participant Roles and Decision Authorities
- 6. Rules of Engagement
- 7. Scenario Summary
- 8. Exercise Timeline and Injects
- 9. Facilitator Prompt Bank
- 10. Executive View
- 11. Operational View
- 12. Technical View
- 13. Communications Considerations
- 14. Success Criteria
- 15. Debrief Questions
- 16. Recommended Improvement Areas
- 17. MITRE ATT&CK Mapping
- 18. Source-to-Scenario Traceability
- 19. Optional Layout / Visual Suggestions and Glossary

## 1. Exercise Overview

This tabletop exercise simulates a cyber incident originating from a third-party core banking SaaS provider that supports account servicing and loan-management workflows. A malicious compromise of the vendor's software update channel results in service disruption, uncertainty about downstream exposure, and pressure to restore service before full technical assurance is available.

The exercise tests incident response, crisis coordination, service continuity, third-party assurance, customer communications, and decision-making under uncertainty. The revised scenario explicitly forces participants to distinguish vendor-side compromise from bank-side exposure, while still requiring operational continuity decisions in the absence of complete information.

### Core exercise tension

- Business teams need account-servicing functions restored quickly to reduce customer harm and backlog.
- Security and technology teams need evidence that the compromised vendor environment is trustworthy before reconnecting.
- Legal, compliance, and communications teams must decide what can be said externally when facts are incomplete and vendor claims are still being validated.
- Executives must document risk acceptance, restoration decisions, customer-impact thresholds, and regulator/board escalation choices.

### Revision focus incorporated from evaluation feedback

- Added a concrete integration model: mutual TLS, OAuth2 service account, SSO, vendor API, file exchange, and logging sources.
- Defined the adversary path: compromised vendor CI/CD token, signed malicious update, container execution, token access attempt, HTTPS command-and-control, metadata exfiltration, and service disruption.
- Added bank-side observable artifacts that participants can request and validate instead of relying only on generic vendor statements.
- Corrected governance flow: the SOC owns technical isolation/reconnection execution under incident response authority; the crisis cell owns business continuity, customer impact, and risk acceptance.
- Rebuilt the ATT&CK mapping so each listed tactic/technique is tied to an explicit scenario fact rather than a speculative possibility.

## 2. Background Context

The participating bank relies on a vendor-managed loan servicing and account management platform, referred to here as CoreServ SaaS, for key customer servicing functions. The platform is used by branch and contact-center personnel to support account maintenance, loan servicing, payment arrangements, hardship workflows, complaints handling, and other servicing activities.

CoreServ SaaS is not the sole system of record for all banking operations, but it is a critical workflow platform. Prolonged unavailability affects customer servicing capacity, staff workload, control quality, backlog management, and customer harm outcomes.

## Scenario architecture snapshot

| Area               | Exercise detail                                                                                                                                                                                                     |
|--------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| User access        | Branch and contact-center users authenticate through corporate SSO to reach the vendor-hosted application portal. Privileged vendor-administration access is restricted to a small application support group.       |
| API integration    | A bank integration gateway initiates outbound HTTPS/mTLS connections to the vendor API endpoint for account-maintenance workflow updates, status lookups, and case synchronization.                                 |
| Authentication     | The integration uses OAuth2 client credentials tied to a scoped service account named svc-coreserv-prod-api. Secrets are stored in a vault and rotated under change control.                                        |
| Data exchange      | Daily reconciliation and exception reports are exchanged through a managed file-transfer channel. Real-time customer servicing remains dependent on the vendor portal and API.                                      |
| Logging sources    | Relevant bank-side telemetry includes API gateway logs, proxy logs, firewall egress logs, IdP/SSO logs, EDR alerts on support workstations, application logs, ServiceNow incident data, and SIEM correlation rules. |
| Vendor environment | The vendor operates a containerized SaaS application. Updates are distributed through a CI/CD pipeline that signs update manifests and promotes container images into customer tenant namespaces.                   |

## Assumptions used to expand the scenario

- The bank maintains network integrations with the vendor-hosted servicing platform but does not host the vendor application code inside the bank production network.
- No confirmed compromise of bank endpoints, bank servers, or bank customer data is known at exercise start.
- The primary customer impact is on account servicing, hardship handling, loan/account administration, and branch/contact-center support.
- Regulatory, legal, privacy, and customer-notification decisions depend on materiality, operational disruption, data exposure, jurisdiction, and what the vendor later confirms.
- The SOC can execute emergency technical containment, including temporary isolation of vendor routes, API credentials, and integration pathways, under existing incident response authority.
- The crisis management structure coordinates the business consequences of containment: customer service priorities, manual fallback, backlog acceptance, communications, and risk acceptance.

## Technical facts available to the facilitator

- A vendor CI/CD automation token was misused to promote a malicious hotfix package identified as CoreServ-2026.07.12.3-hotfix.
- The hotfix manifest was signed with a legitimate vendor signing process, which allowed it to pass normal release checks.
- The malicious update executed a shell-based post-install routine inside vendor application containers and created a Kubernetes CronJob named svc-update-metrics in affected tenant namespaces.
- The payload enumerated container resources, attempted to read mounted application configuration and token files, and attempted to export tenant metadata over HTTPS to adversary-controlled infrastructure.
- The payload stopped or disabled a job scheduler used for account-maintenance and servicing workflows, causing application instability and downstream customer-servicing disruption.
- Bank-side logs show service degradation and suspicious API behavior from vendor-originating infrastructure, but no confirmed bank-side host compromise.

## 3. Exercise Objectives

By the end of the exercise, participants should be able to:

- 1 Demonstrate clear escalation and crisis governance for a material third-party cyber incident.

- 2 Differentiate third-party operational outage management from cyber containment and bank-side exposure analysis.
- 3 Assess operational impact when a vendor-hosted servicing platform becomes unavailable.
- 4 Decide how and when to isolate vendor-integrated services from the bank network and who has authority to act.
- 5 Execute customer servicing workarounds, prioritize critical customer needs, and preserve compensating controls.
- 6 Identify realistic evidence required from the vendor at each stage of the incident.
- 7 Evaluate assurance requirements before reconnecting a previously isolated third-party service.
- 8 Review bank-side telemetry for indicators of compromise, token misuse, anomalous API behavior, and exposure through trusted integrations.
- 9 Coordinate internal and external communications, including leadership, customers, regulators, and the vendor.
- 10 Capture lessons learned for resilience, vendor governance, token management, dependency mapping, and recovery criteria.

## 4. Scope

| In scope                                                                                                                                                                                                                                                                                                                         | Out of scope                                                                                                                                                                                                                                                                                                       |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Third-party cyber incident response; crisis management and escalation; service continuity and manual fallbacks; vendor risk and assurance; customer communications; technology containment and reconnection decisions; legal/compliance/regulatory assessment; bank-side telemetry review; post-incident review and remediation. | Deep forensic analysis of the vendor environment; live production technical recovery actions; detailed contract dispute resolution; jurisdiction-specific legal advice; adversary attribution beyond what is needed for risk decisions; hands-on technical containment outside normal change/emergency procedures. |

Facilitators should keep participants focused on decisions they would realistically own. The exercise is not a technical forensics lab, but it should require enough technical precision to support safe containment and restoration decisions.

## 5. Participant Roles and Decision Authorities

### Recommended participant groups

| Group                         | Representative roles                                                                                                    | Primary exercise focus                                                                                                                 |
|-------------------------------|-------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| Executive / crisis leadership | Country or business leadership, crisis management lead, CISO or delegate, operations leadership                         | Materiality, risk appetite, customer harm, board/regulator visibility, formal crisis declaration, restoration risk acceptance          |
| Operational stakeholders      | Branch operations, contact center, loan servicing, business continuity, complaint handling, vulnerable-customer support | Manual servicing, customer prioritization, backlog, workarounds, compensating controls, frontline instructions                         |
| Technical stakeholders        | SOC/IR, infrastructure/network, IAM, application support, integration owners, architecture, service management          | Isolation, telemetry review, token/certificate control, vendor evidence, reconnection validation, enhanced monitoring                  |
| Control functions             | Legal, compliance, privacy, regulatory affairs, third-party risk, internal audit observer                               | Notification thresholds, outsourcing obligations, privacy assessment, evidence preservation, vendor assurance, post-incident reporting |
| Communications                | Internal communications, external communications, media relations, customer communications                              | Consistent messaging, holding statements, frontline scripts, executive updates, regulator/media coordination                           |
| Vendor liaison                | Third-party relationship owner, vendor manager, application owner                                                       | Information requirements, escalation into vendor, evidence collection, recovery timelines, contractual obligations                     |

## Decision authority model

| Decision                                        | Recommended owner                                                                                            | Consulted parties                                             | Expected record                                                  |
|-------------------------------------------------|--------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------|------------------------------------------------------------------|
| Open and classify incident                      | SOC Incident Commander / Major Incident Manager                                                              | Application owner, operations, service management             | Incident ticket, severity rationale, affected services           |
| Temporarily isolate vendor integration          | SOC Incident Commander under emergency containment authority                                                 | Network/IAM, app owner, crisis lead, business owner           | Containment action log, business impact note, rollback path      |
| Declare formal crisis or restricted crisis cell | Crisis Management Lead / executive leadership                                                                | SOC, operations, legal, communications                        | Crisis declaration, stakeholder roster, cadence                  |
| Activate manual servicing                       | Operations / business continuity lead                                                                        | Branch/contact center, controls, legal/compliance             | Manual procedure version, controls, exception log                |
| Notify regulator or customer                    | Legal/compliance/privacy with executive approval                                                             | Operations, SOC, communications, vendor management            | Notification analysis, decision record, approved message         |
| Reconnect vendor service                        | Joint sign-off: SOC + application owner + business owner; executive risk acceptance if residual risk remains | IAM, network, third-party risk, legal/compliance, crisis lead | Reconnection criteria checklist, evidence package, rollback plan |

## 6. Rules of Engagement

- This is a no-fault exercise intended to identify strengths, gaps, and improvement areas.
- Participants should respond based on their current roles, authorities, processes, and available tooling.
- Real incidents take priority over the exercise.
- Assume the scenario is real unless the facilitator states otherwise.
- Do not solve the scenario by assuming facts that have not been provided.
- Participants may request additional facts from the facilitator; the facilitator may provide evidence cards if the request is realistic.
- No live production changes should be made as part of the exercise unless separately authorized through normal emergency procedures.
- The named platform and vendor are exercise constructs; they are selected to stimulate discussion, not to imply known concerns.

## 7. Scenario Summary

A core banking SaaS provider used by the bank for account servicing and loan-management workflows suffers a cyber incident involving compromise of its software update channel. The vendor notifies customers of service instability after a malicious hotfix affects tenant application components. The bank begins experiencing loss of account-servicing capability in branch and contact-center channels.

As the incident develops, the SOC isolates vendor-connected services, IAM teams evaluate exposed service accounts and tokens, operations activate manual servicing procedures, and leadership manages customer-impact trade-offs. The vendor later claims remediation is complete, but the bank must decide whether vendor evidence is sufficient to restore connectivity. The central question is what minimum evidence is needed before reconnecting a critical third-party service to the bank environment.

### Defined adversary path for exercise realism

- 1 Initial vendor compromise: The adversary obtains a valid vendor CI/CD automation token and uses it to promote a malicious hotfix package through the vendor's normal release workflow.

- 2 Software supply-chain abuse: The malicious package is signed through the vendor's legitimate process and deployed to selected customer tenant namespaces, including the bank's tenant.
- 3 Execution and persistence: A shell-based post-install routine executes inside vendor application containers and creates a Kubernetes CronJob to re-run the payload periodically.
- 4 Discovery and credential access: The payload enumerates container resources and attempts to read mounted configuration, application credentials, OAuth tokens, and service-account material.
- 5 Command-and-control and exfiltration: The payload communicates over HTTPS to an adversary-controlled domain and exports limited tenant metadata and integration configuration.
- 6 Impact: The payload stops a servicing job scheduler, causing account-maintenance API failures and loss of key branch/contact-center functionality.
- 7 Downstream bank exposure: Bank-side telemetry shows suspicious but limited interaction from vendor infrastructure. There is no confirmed bank host compromise, but token misuse and trusted integration abuse must be investigated.

#### Facilitator framing

- Participants should not be given the full adversary path at the start.
- Reveal technical details through inject evidence cards only when participants ask for vendor evidence, bank logs, or technical validation.
- Strong teams should converge on containment, manual servicing, vendor evidence requirements, credential rotation, and staged reconnection without assuming the vendor's statement is sufficient.

## 8. Exercise Timeline and Injects

| Inject                                                  | Exercise time | Main tension                                                    | Primary decision                                                  |
|---------------------------------------------------------|---------------|-----------------------------------------------------------------|-------------------------------------------------------------------|
| 1 - Vendor advisory and degraded servicing              | Day 1, 09:00  | Known service degradation, cyber suspicion not yet fully scoped | Severity, escalation, immediate triage, information requirements  |
| 2 - Bank-side isolation and sustained disruption        | Day 1, 12:00  | Cyber facts emerge; containment creates business impact         | Maintain isolation, rotate credentials, activate manual servicing |
| 3 - Vendor claims remediation complete                  | Day 2, 10:00  | Vendor says it is safe; bank has not independently validated    | Reconnect, reconnect conditionally, or remain isolated            |
| 4 - Controlled restoration and after-action obligations | Day 3, 09:00  | Service returning but backlog and reporting remain              | Monitoring, customer recovery, reporting, resilience improvements |

**Inject 1 - Vendor advisory and degraded servicing**

**Day 1, 09:00**

**Recognize third-party cyber risk while managing customer service impact**

### Situation

The core banking SaaS provider notifies customers that it is responding to an incident associated with a software update. Shortly afterward, the bank experiences disruption in account-servicing functions used by branch and contact-center teams. Staff report that they cannot reliably perform account maintenance, hardship processing, payment arrangements, and certain loan-servicing actions through the usual platform.

### What participants know

- The vendor has acknowledged an incident linked to a software update but has not yet confirmed full scope.
- The bank is experiencing loss or degradation of customer-servicing functions.
- API gateway logs show elevated 502/504 errors to the vendor endpoint and increased retry traffic from the integration gateway.

- The vendor states that the affected version may be CoreServ-2026.07.12.3-hotfix, but this is not yet confirmed.
- No confirmed evidence indicates compromise inside the bank environment.
- The duration, affected tenants, and data exposure remain unclear.

### Facilitator evidence card - available if requested

| Evidence source              | Fictional artifact                                                                                               | Facilitator interpretation                                                                |
|------------------------------|------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|
| ServiceNow / incident ticket | P1 candidate for service impact; cyber severity under assessment                                                 | Participants should decide whether to open both major incident and cyber incident tracks. |
| API gateway                  | Between 08:42 and 09:08, 38% of calls to api.coreserv.example return 502/504                                     | Confirms business impact and technical degradation; does not prove bank compromise.       |
| Vendor advisory              | Investigating software update irregularity; customers should monitor integrations and await containment guidance | Ambiguous by design. Strong teams request more precise facts.                             |
| SSO logs                     | Normal user logins to vendor portal; no anomalous bank employee authentication observed                          | Helps avoid over-rotating to bank endpoint compromise before evidence exists.             |

### Discussion questions

- What is the initial severity assessment, and who owns the classification?
- Which response structure is activated: cyber incident, major incident, crisis cell, or all three with clear ownership?
- Which customer-facing services are critically affected and how will business impact be measured?
- Which servicing activities must be prioritized in the first two hours?
- What immediate containment, monitoring, and triage actions should be initiated without disrupting necessary operations unnecessarily?
- What workarounds are available for branch and contact-center staff?
- Who must be informed internally in the first 30-60 minutes?
- What facts must be obtained from the vendor immediately?

### Expected actions

- Open and classify the incident with both service-impact and cyber-risk dimensions.
- Activate third-party incident escalation procedures and identify the vendor relationship owner.
- Identify business processes, APIs, service accounts, and data flows dependent on the affected platform.
- Increase monitoring of vendor-originating traffic, API errors, token activity, and SSO access.
- Prepare emergency isolation options, including disabling vendor routes, suspending API credentials, blocking untrusted vendor IPs, and pausing file exchange.
- Stand up manual fallback procedures for urgent customer needs.
- Establish a bank-side information requirement list for the vendor.

### Facilitator notes

Look for whether participants separate operational outage management from cyber containment while coordinating both. Strong responses should identify urgent customer-impact categories such as hardship requests, vulnerable-customer support, delinquency servicing, complaint handling, time-sensitive account actions, and regulator-driven deadlines. Participants should not assume that vendor update compromise equals bank compromise, but they should treat trusted integrations as potential exposure paths.

### Sample evidence requests to the vendor



- Nature of the incident, current status, and whether the event is confirmed cyber-related.
- Affected update version, deployment time window, and affected tenants or regions.
- Whether malicious code was distributed through the update mechanism.
- Whether customer tenants are logically isolated and whether tenant-specific data was accessed.
- Known indicators of compromise, hashes, domains, IPs, affected certificates, and detection logic.
- Whether service accounts, OAuth tokens, certificates, or API credentials should be rotated.
- Recommended customer-side containment measures and expected recovery timeline.

Inject 2 - Bank-side isolation and sustained disruption

Day 1, 12:00

Contain trusted vendor exposure while preserving customer servicing

Situation

The vendor provides a preliminary forensic bulletin confirming that a signed hotfix package was maliciously modified through its update channel. The SOC determines that continued trust in vendor-integrated pathways is not acceptable until exposure is assessed. The SOC isolates or suspends vendor API connectivity, pauses managed file transfer, and disables the affected OAuth client credential pending rotation. Manual servicing is now in effect for priority cases. Queue times are rising in contact centers, branch staff are escalating exceptions, and business leaders want to know how long manual mode can continue without customer harm or control failures.

What participants know

- The vendor service remains unstable or unavailable.
- The incident is now confirmed as cyber-related and linked to a malicious update package.
- Vendor preliminary IOCs include update version CoreServ-2026.07.12.3-hotfix, SHA256 hash f0c2...b7a9, and outbound HTTPS to telemetry-sync.coreserv-update.example from affected containers.
- Bank API gateway logs show attempted calls using svc-coreserv-prod-api from a new vendor egress IP in the 203.0.113.0/24 documentation range; most calls failed authorization after SOC containment.
- The SOC has isolated or suspended vendor-integrated connections pending reconnection criteria.
- Manual servicing is underway and customer backlogs are building.
- There is still no clear vendor recovery ETA.

Facilitator evidence card - available if requested

| Evidence source          | Fictional artifact                                                                                                         | Facilitator interpretation                                                                 |
|--------------------------|----------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| Vendor bulletin          | Compromised CI/CD token used to promote signed hotfix; malicious container CronJob discovered                              | Confirms supply-chain compromise and vendor-side persistence mechanism.                    |
| Bank proxy/firewall logs | Outbound bank traffic to vendor blocked after 11:42; no direct bank egress to adversary domain                             | Supports bank-side containment and no direct C2 from bank network.                         |
| API gateway              | Unexpected vendor source IP attempted account-status and case-search API calls; 401/403 after token suspension             | Requires token/key/certificate review. Does not confirm successful bank data exfiltration. |
| IAM / vault              | svc-coreserv-prod-api secret last rotated 87 days ago; emergency rotation procedure exists but requires app owner approval | Drives discussion on emergency credential rotation and ownership.                          |
| Operations               | Manual queue: 280 cases; 37 hardship-related; 18 time-sensitive payment arrangements; complaints SLA risk in 11 cases      | Forces prioritization and control overlay discussion.                                      |

Decision points

- Should the bank maintain full isolation, allow limited read-only access, or allow no connectivity until vendor evidence improves?
- Should the bank rotate or revoke OAuth client credentials, mTLS certificates, API keys, and vendor admin accounts immediately?
- What customer-impact threshold triggers a formal crisis cell or executive risk acceptance?
- What manual servicing controls are required to operate safely during prolonged disruption?

### Discussion questions

- Who has authority to isolate or maintain isolation of the vendor-integrated service?
- What monitoring should be enhanced while the platform remains disconnected?
- How will high-risk or high-priority customer cases be handled?
- What compensating controls are required for manual servicing?
- What is the threshold for escalating to a formal crisis-management structure?
- What are the communications to frontline teams, senior management, and relationship managers?
- Are any regulatory notifications triggered by disruption alone, even without confirmed data compromise?
- What minimum evidence would change the bank's containment posture?

### Expected actions

- Maintain containment of vendor-connected services until risk is assessed and documented.
- Rotate or revoke scoped service accounts, API secrets, tokens, and certificates where exposure is plausible.
- Track critical service impacts, backlog growth, customer harm, complaints, control exceptions, and manual processing error rates.
- Activate an approved manual operating procedure with segregation of duties and maker-checker controls.
- Define customer-priority tiers and exception-routing paths.
- Record decisions, risk acceptance, temporary control changes, and escalation rationale.
- Coordinate internal messaging to avoid inconsistent communications.

### Facilitator notes

Push participants on how they preserve control quality during manual operations. Good answers should address maker-checker controls, approval overrides, call recording, audit trails, exception logs, customer vulnerability handling, workload prioritization, and temporary access governance. Also push technical teams on why isolation is not merely a network decision: credentials, certificates, token lifetimes, OAuth scopes, file exchange, and vendor admin access must also be considered.

**Inject 3 - Vendor claims remediation complete**

**Day 2, 10:00**

**Restore service only if evidence supports trust restoration**

### Situation

The vendor states that remediation is complete and that services are ready to be restored. Manual servicing remains operational but strained. Senior business leaders are pressing for restoration to reduce customer harm and backlog. The SOC has not yet independently validated safe reconnection. The vendor provides a short customer notice stating that the issue has been contained and normal service can resume, followed by a more detailed evidence package after the bank requests it.

### What participants know

- The vendor says the threat has been mitigated.

- The vendor confirms the malicious hotfix has been rolled back and the compromised CI/CD token revoked.
- Vendor states the malicious CronJob was removed from affected tenant namespaces and container images have been rebuilt from a clean baseline.
- Vendor confirms 72 KB of tenant metadata and integration configuration was exfiltrated from affected environments; no customer PII, account balances, or transaction data are confirmed exposed at this stage.
- The bank has not identified direct bank host compromise, but the SOC is still reviewing API logs, proxy logs, and token activity.
- Manual servicing remains controlled but strained.

## Decision point

### Main decision

Should the bank reconnect now, reconnect conditionally under enhanced controls, or remain isolated pending further assurance?

## Vendor evidence package

| Evidence item                        | Vendor statement                                                                                                     | Bank validation action                                                            |
|--------------------------------------|----------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|
| Root cause summary                   | CI/CD automation token misused; malicious hotfix promoted through normal signing workflow                            | Assess whether root cause is specific enough to support corrective actions.       |
| Containment and eradication timeline | Token revoked, hotfix removed, affected containers rebuilt, malicious CronJob removed                                | Compare timeline with bank log windows and outage timeline.                       |
| Customer-specific impact             | Bank tenant affected by deployment; metadata/configuration exfiltration confirmed; no PII/transaction data confirmed | Legal/privacy assessment; confirm what data fields are in metadata/configuration. |
| Indicators and detections            | Hash, container image digest, C2 domain, source IPs, Kubernetes object names, affected release identifiers           | Search SIEM, API gateway, proxy, firewall, EDR, and SSO logs.                     |
| Credential remediation               | Vendor-side secrets rotated; customer OAuth credentials should be rotated before restoration                         | Rotate bank service credentials and validate scoped permissions.                  |
| Integrity validation                 | Clean image digests, signed build attestation, production namespace scan, monitoring enhancements                    | Require named vendor authority and evidence of tenant-specific checks.            |
| Restoration plan                     | Service can resume; vendor recommends staged reconnection and monitoring for 24 hours                                | Define bank-side staged restoration, rollback, and burn-in criteria.              |

## Discussion questions

- What minimum assurance is required before reconnection?
- Which teams must sign off on reconnection, and who records the final decision?
- What evidence from the vendor is necessary and sufficient?
- What bank-side technical validation is needed before restoring connectivity?
- Should the service be restored read-only, limited-scope, or fully restored?
- What are the risks of reconnecting too early versus staying disconnected too long?
- How should the bank communicate the decision to staff, customers, regulators, and the vendor?
- Does confirmed metadata/configuration exfiltration change privacy, legal, contractual, or regulatory notification analysis?

## Expected actions

- Define formal reconnection criteria and assign owners for each evidence item.

- Require vendor evidence before trust is restored, including a named attestation from an accountable vendor authority.
- Rotate exposed or plausibly exposed service credentials, OAuth client secrets, certificates, and privileged vendor admin access.
- Assess bank-side exposure across API logs, proxy/firewall telemetry, SSO logs, EDR, application logs, and integration error patterns.
- Use a staged or conditional reconnection approach with enhanced monitoring, traffic allowlisting, and rollback procedures.
- Document business and security sign-off, residual risks, and risk acceptance rationale.
- Preserve evidence for post-incident review, regulatory assessment, and vendor management follow-up.

### Suggested reconnection criteria

- 1 Formal vendor incident declaration and remediation summary received.
- 2 Customer-specific impact statement received, including affected tenant, data categories, time window, and exposure assessment.
- 3 Vendor confirms malicious update, persistence mechanism, and related infrastructure have been removed.
- 4 Vendor confirms CI/CD token revocation, signing-process validation, and build pipeline integrity checks.
- 5 Relevant IOCs reviewed by bank security teams across applicable telemetry sources.
- 6 Bank rotates or revokes affected OAuth client secrets, service-account tokens, API keys, mTLS certificates, and vendor admin credentials.
- 7 No evidence of successful unauthorized bank API access or bank-side host compromise.
- 8 Enhanced monitoring and alert thresholds are in place for the burn-in period.
- 9 Staged restoration plan agreed: test, read-only or limited-scope, monitored full restoration.
- 10 Rollback or re-isolation plan prepared and tested before reconnection.
- 11 Business owner, application owner, SOC, and executive risk owner sign off.

### Facilitator notes

This is the core governance moment of the exercise. Participants should not treat vendor restoration claims as automatically sufficient. Strong responses balance customer harm from continued outage against residual cyber risk from premature reconnection. Teams should be explicit about what evidence is required, who can accept residual risk, and how a rollback will occur if suspicious behavior resumes.

**Inject 4 - Controlled restoration and after-action obligations**

**Day 3, 09:00**

**Recover operations and convert lessons into resilience improvements**

### Situation

After completing validation steps, the bank restores the vendor-connected platform in a controlled manner. Core account-servicing functions are returning to normal under enhanced monitoring, but significant backlog remains. Leadership requests a post-incident review covering operational impact, customer harm, vendor performance, evidence quality, technical control gaps, regulatory considerations, and improvements to third-party cyber resilience.

### What participants know

- Connectivity has been restored under enhanced monitoring with a rollback plan in place.
- Priority servicing is stabilizing, but backlog clearance will take several days.
- All CoreServ OAuth client credentials and mTLS certificates have been rotated.

- SOC monitoring shows no recurrence of anomalous vendor traffic during the first 12 hours of burn-in.
- The incident has raised questions about vendor governance, dependency concentration, token rotation cadence, manual fallback maturity, and reconnection criteria.
- Post-incident reporting obligations may apply, especially given material service disruption and confirmed tenant metadata/configuration exfiltration at the vendor.

### Discussion questions

- What must happen in the first 24-72 hours after restoration?
- How should customer backlog and service recovery be prioritized?
- What customer harm metrics should be tracked and reported?
- What notifications, reports, or board-level briefings are required?
- What contractual, third-party risk, or assurance issues should be reviewed with the vendor?
- What strategic improvements are needed to reduce concentration risk and improve resilience?
- How will lessons be tracked to closure and who owns the remediation plan?

### Expected actions

- Maintain heightened monitoring for a defined observation period.
- Validate data integrity, transaction completeness, case synchronization, and backlog disposition.
- Conduct operational debriefs with branches, contact centers, loan servicing, and complaint teams.
- Complete legal, privacy, regulatory, and contractual notification analysis.
- Conduct internal after-action review and collect evidence for reporting.
- Review vendor performance, incident notification timeliness, forensic evidence quality, and remediation commitments.
- Update crisis playbooks, reconnection protocols, token rotation procedures, monitoring detections, and manual fallback procedures.
- Track remediation actions through governance until closure.

### Facilitator notes

Good responses move beyond technical restoration. Participants should identify resilience improvements such as vendor evidence clauses, dependency mapping, service-account scoping, token rotation SLAs, customer-impact metrics, continuity testing, tabletop cadence, and board reporting on concentration risk.

## 9. Facilitator Prompt Bank

Use these prompts if discussion slows or becomes too procedural:

- What is the single most important decision in the first hour?
- Which customer populations would be harmed most by prolonged servicing disruption?
- What specific facts would make you classify this as a cyber incident rather than a vendor outage?
- How do you distinguish business urgency from security assurance?
- Who can authorize isolation, and who accepts the business impact of isolation?
- What evidence would make you comfortable reconnecting?
- What if the vendor refuses to share detailed forensics or tenant-specific logs?
- What if regulators ask why the bank trusted the vendor's statement?
- What if manual servicing causes a spike in complaints or control exceptions?
- What would executives want to know every two hours during the disruption?
- Which logs would prove or disprove token misuse from vendor infrastructure?
- What is the fallback if OAuth token rotation breaks legitimate integrations?
- How would the answer change if customer PII were confirmed exposed?
- What if the vendor can restore service only if the bank reconnects before all evidence is available?
- Which lessons belong in vendor governance versus incident response versus business continuity?

## 10. Executive View

Executives should focus on customer harm, decision rights, service restoration risk, regulatory visibility, business resilience, and third-party dependency concentration. They should avoid technical over-management but require evidence-based recommendations from the SOC, operations, legal/compliance, and vendor management teams.

### Executive decision themes

- Whether to declare a formal crisis or restricted crisis-management cell.
- Whether to maintain isolation of vendor-linked services despite operational pressure.
- What customer communications are needed and when.
- Whether vendor evidence is enough to reconnect or whether additional assurance is mandatory.
- What level of residual cyber risk can be accepted and who records that acceptance.
- What customer harm thresholds trigger senior leadership, board, or regulator updates.
- What strategic remediation should be mandated post-incident.

| Question                             | Good executive response                                                                                                                           |
|--------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------|
| How bad is this?                     | Ask for service impact, customer harm, cyber exposure, data exposure, regulatory triggers, and recovery uncertainty - not only system status.     |
| Should we reconnect?                 | Require a joint recommendation from SOC, application owner, business owner, legal/compliance, and vendor management, tied to documented criteria. |
| What do we tell customers?           | Approve practical, accurate messages that acknowledge service impact without speculating about unconfirmed cyber facts.                           |
| What do we tell the board/regulator? | Provide facts, decisions taken, customer impact, containment posture, residual risk, and next update cadence.                                     |

## 11. Operational View

Operational teams should focus on sustaining customer servicing safely while technology and vendor teams assess the cyber risk. Manual processing must preserve control quality and customer outcomes.

### Operational priorities

- Manual servicing workflows and staffing model.
- Prioritization of urgent customer cases.
- Branch and contact-center guidance.
- Exception handling and control preservation.
- Backlog management and customer communications.
- Complaint, vulnerable-customer, and hardship handling.
- Recovery sequencing once service is restored.

| Priority tier                                | Example cases                                                                                                   | Control expectation                                                  |
|----------------------------------------------|-----------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------|
| Tier 1 - immediate customer harm             | Hardship customers, vulnerable customers, urgent payment arrangements, account blocks affecting access to funds | Same-day handling, supervisor approval, full audit trail             |
| Tier 2 - regulatory or contractual deadlines | Complaints, servicing deadlines, legal/regulatory commitments, time-sensitive account maintenance               | Dedicated queue, maker-checker review, daily reconciliation          |
| Tier 3 - high operational backlog            | Routine loan/account administration, non-urgent maintenance, status requests                                    | Batch processing, transparent customer expectations, backlog metrics |
| Tier 4 - deferrable activity                 | Non-critical changes, reporting enhancements, non-time-sensitive follow-up                                      | Deferred with documented customer communication where appropriate    |

### Manual servicing control checklist

- Approved manual procedure version is available and communicated to frontline teams.
- Maker-checker or supervisor review is used for sensitive account actions.
- All manual actions are logged with customer, timestamp, reason, approver, and evidence.
- Exception queue owner and escalation path are assigned.
- Daily reconciliation is performed after system restoration.
- Temporary access or approval overrides are time-bound and reviewed.
- Customer-impact metrics are reported at agreed cadence.

## 12. Technical View

Technical teams should focus on containment, evidence-based validation, credential and token exposure, telemetry review, and staged reconnection. The exercise should avoid unrealistic expectations that the bank can perform vendor forensics directly, but it should require the bank to validate its own exposure and demand appropriate vendor evidence.

### Technical decision considerations

- Which interfaces, APIs, credentials, certificates, file exchanges, and network paths are affected?
- Are service accounts, API keys, OAuth tokens, SSO trust relationships, or certificates at risk?
- What evidence would show successful versus attempted API misuse?
- Can the service be restored read-only or limited-scope first?

- What rollback options exist if suspicious behavior resumes?
- What telemetry must remain under heightened monitoring during the burn-in period?

## Bank-side telemetry to review

| Telemetry source           | What to look for                                                                                                                                  | Decision relevance                                                                |
|----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|
| API gateway                | Unexpected vendor source IPs, unusual endpoints, abnormal request volumes, failed/unauthorized calls, successful calls outside expected workflows | Assesses possible token misuse and whether unauthorized bank API access occurred. |
| Proxy / firewall egress    | Connections to vendor endpoints, adversary domains, unusual destinations, policy blocks, large transfer volumes                                   | Confirms whether bank network communicated with malicious infrastructure.         |
| IAM / IdP                  | Unexpected vendor admin portal logins, SSO anomalies, privileged account use, impossible travel, failed MFA                                       | Assesses bank user or admin account exposure.                                     |
| Vault / secrets management | Last rotation dates, secret access logs, emergency rotation success, applications consuming affected secrets                                      | Supports credential rotation decisions.                                           |
| EDR                        | Suspicious process activity on application support workstations or integration servers                                                            | Rules out bank endpoint compromise where in scope.                                |
| SIEM correlation           | IOC matches, time-window correlation, anomalies before/after isolation                                                                            | Provides consolidated evidence for sign-off and reporting.                        |
| Service monitoring         | Error rates, latency, queue growth, recovery after reconnection, business transaction success                                                     | Informs operational restoration and rollback thresholds.                          |

## Technical hypotheses for participants to test

- Hypothesis 1: This is limited to vendor-side service disruption with no bank-side compromise.
- Hypothesis 2: The malicious vendor update attempted to use trusted integration credentials against bank APIs.
- Hypothesis 3: A bank service account, token, or certificate was exposed and must be rotated before reconnection.
- Hypothesis 4: No bank customer data was exfiltrated from bank systems, but vendor-side metadata/configuration exposure may still trigger contractual, legal, or regulatory review.
- Hypothesis 5: Reconnection is safe only if vendor remediation evidence, bank telemetry review, credential rotation, and enhanced monitoring criteria are satisfied.

## Minimum technical reconnection package

- Vendor root-cause summary and containment/eradication timeline.
- Affected version, image digest, code-signing details, and deployment windows.
- IOCs: hashes, domains, IPs, container object names, filenames, process names, and log patterns.
- Tenant-specific impact statement and data category assessment.
- Confirmation of token/certificate revocation and rotation on vendor side.
- Bank-side credential rotation completed and validated.
- Clean SIEM/API/proxy/IAM review for the relevant time window.
- Staged restoration plan and rollback procedure.
- Burn-in monitoring rules and alert ownership.

# 13. Communications Considerations

## Internal communications



- Situation status and impact summary.
- Approved talking points for frontline staff.
- Clear statement of what is known, unknown, and under investigation.
- Escalation path for customer exceptions and complaints.
- Frequency of leadership updates.
- Reminder not to speculate about vendor forensics, data exposure, or restoration timelines.

### External communications

- Customer notices if service degradation becomes material or prolonged.
- Messaging to critical partners, outsourcers, or relationship managers.
- Regulator communications if material service disruption, outsourcing obligations, privacy thresholds, or incident-reporting rules are triggered.
- Vendor-facing communications that preserve rights and request evidence without creating inconsistent public narratives.
- Media holding statements if the incident becomes public.

### Key messaging principles

- Acknowledge service impact without speculating.
- Avoid promising timelines that the bank cannot control.
- Distinguish vendor statements from bank-validated facts.
- Keep customer guidance practical and consistent.
- Use consistent terminology: service disruption, third-party cyber incident, investigation, containment, restoration, and enhanced monitoring.

### Sample external holding statement

#### Holding statement

We are aware of a service disruption affecting a third-party platform used for certain account-servicing workflows. Our teams have activated continuity procedures to support customers and are working with the provider to validate safe restoration. At this stage, our review has not identified unauthorized access to bank systems. We will provide practical customer guidance if service impacts continue.

## 14. Success Criteria

The exercise is successful if participants:

- Escalate the incident appropriately and quickly.
- Separate cyber containment, technology service recovery, and business continuity responsibilities.
- Identify critical dependencies, integration paths, credentials, and impacted services.
- Make a clear containment decision for the vendor-integrated platform and document authority.
- Implement workable manual servicing with compensating controls.
- Define concrete reconnection criteria rather than relying on vendor assurances alone.
- Use bank-side telemetry and vendor evidence to validate exposure and restoration readiness.
- Coordinate business, technical, legal, compliance, communications, and vendor management functions effectively.

- Identify practical resilience improvements for third-party cyber events.
- Produce a clear after-action record with owners, deadlines, and governance tracking.

## 15. Debrief Questions

- What worked well in the response model?
- Where were decision authorities unclear?
- Did the organization have enough visibility into third-party dependencies?
- Did the team understand the affected integration paths, credentials, and data flows?
- Were manual workarounds realistic and controlled?
- Was the threshold for safe reconnection clearly understood?
- Which stakeholders were engaged too late or not at all?
- What would improve customer-outcome management during sustained disruption?
- What vendor evidence was missing or delayed?
- Did the MITRE ATT&CK mapping help technical teams structure validation, or did it create confusion?
- Which control, contractual, or architecture changes should be prioritized next?
- What should be tested again in the next tabletop or technical validation exercise?

## 16. Recommended Improvement Areas

| Area                  | Recommended improvement                                                                                                                                      | Owner candidates                            |
|-----------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------|
| Dependency mapping    | Maintain a current inventory of critical third-party services, data flows, integration owners, authentication methods, and outage criticality.               | Third-party risk, architecture, app owners  |
| Isolation playbooks   | Create vendor-originated cyber incident playbooks covering network isolation, credential suspension, file transfer pause, admin portal access, and rollback. | SOC, network, IAM, application support      |
| Reconnection protocol | Define evidence-based reconnection criteria, joint sign-off requirements, burn-in monitoring, and residual risk acceptance records.                          | SOC, app owner, crisis management, risk     |
| Credential governance | Reduce long-lived service credentials, enforce scoped OAuth permissions, rotate tokens more frequently, and test emergency rotation.                         | IAM, app owners, security architecture      |
| Vendor contracts      | Strengthen incident-notification SLAs, tenant-specific evidence requirements, IOCs, root-cause reports, attestation, and audit rights.                       | Third-party risk, legal, procurement        |
| Monitoring            | Build SIEM use cases for trusted vendor anomalies, unexpected vendor source IPs, token misuse, API enumeration, and unusual data volumes.                    | SOC, detection engineering                  |
| Manual fallback       | Preapprove manual servicing procedures with maker-checker controls, audit trails, customer tiers, and reconciliation steps.                                  | Operations, business continuity, controls   |
| Customer impact       | Define customer harm metrics and escalation thresholds for sustained third-party outages.                                                                    | Operations, customer experience, compliance |
| Regulatory readiness  | Prepare jurisdiction-specific decision trees for material operational disruption, outsourcing incidents, and privacy/data exposure.                          | Legal, compliance, regulatory affairs       |
| Exercise cadence      | Run annual third-party cyber disruption exercises and targeted technical drills for token rotation and reconnection.                                         | Crisis management, SOC, business continuity |

## 17. MITRE ATT&CK Mapping

This mapping reflects behaviors explicitly represented in the revised scenario. It is intended for exercise design, validation, and discussion. Techniques are not listed if the scenario does not provide supporting facts. The most important ATT&CK concepts are software supply-chain compromise, trusted relationship abuse, token exposure, containerized SaaS persistence, command-and-control over web protocols, limited metadata exfiltration, and service disruption.

### Evidence-backed tactics, techniques, and sub-techniques

| Tactic                                         | Technique                                                                   | Scenario evidence                                                                                                           | Exercise validation question                                                                            |
|------------------------------------------------|-----------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------|
| Initial Access                                 | T1195.002 - Supply Chain Compromise: Compromise Software Supply Chain       | Vendor update mechanism is manipulated; malicious hotfix is signed and distributed through normal release process.          | What evidence proves the update channel was compromised and which customer tenants received the update? |
| Initial Access                                 | T1199 - Trusted Relationship                                                | Bank exposure arises through trusted vendor SaaS integrations, API allowlisting, and delegated vendor service connectivity. | Which trusted paths could propagate risk into the bank and how are they contained?                      |
| Initial Access / Persistence / Defense Evasion | T1078.004 - Valid Accounts: Cloud Accounts                                  | Compromised vendor CI/CD automation token is used to promote the malicious update through the vendor environment.           | Which vendor and bank service accounts, tokens, and certificates require revocation or rotation?        |
| Execution                                      | T1059.004 - Command and Scripting Interpreter: Unix Shell                   | The malicious update executes a shell-based post-install routine inside vendor Linux/container workloads.                   | What logs or vendor evidence show first execution and child processes?                                  |
| Persistence / Execution                        | T1053.007 - Scheduled Task/Job: Container Orchestration Job                 | Payload creates a Kubernetes CronJob named svc-update-metrics to re-run in affected tenant namespaces.                      | Has the vendor removed orchestration jobs and validated no recurrence?                                  |
| Discovery                                      | T1613 - Container and Resource Discovery                                    | Payload enumerates pods, services, config maps, and service-account resources in the vendor tenant namespace.               | What container/Kubernetes audit logs should the vendor provide?                                         |
| Credential Access                              | T1552.001 - Unsecured Credentials: Credentials In Files                     | Payload attempts to read mounted configuration and credential files from application containers.                            | Were secrets stored in files or mounted volumes, and what rotation is required?                         |
| Credential Access                              | T1528 - Steal Application Access Token                                      | Payload attempts to access OAuth/service-account token material used by the vendor integration.                             | Were tokens accessed, copied, or used, and what token lifetime controls exist?                          |
| Defense Evasion / Lateral Movement             | T1550.001 - Use Alternate Authentication Material: Application Access Token | Suspicious API calls from vendor infrastructure attempt to use or refresh application tokens against bank integrations.     | Did any unauthorized requests succeed before token suspension?                                          |
| Command and Control                            | T1071.001 - Application Layer Protocol: Web Protocols                       | Malicious vendor containers beacon over HTTPS to telemetry-sync.coreserv-update.example.                                    | Which proxy, DNS, firewall, or vendor egress logs confirm the C2 path?                                  |
| Exfiltration                                   | T1041 - Exfiltration Over C2 Channel                                        | Vendor confirms limited tenant metadata and integration configuration were exported over the HTTPS C2 channel.              | What categories of data left the vendor environment and do notification thresholds apply?               |
| Impact                                         | T1489 - Service Stop                                                        | Payload stops or disables the servicing job scheduler, causing account-maintenance workflow disruption.                     | Was the disruption maliciously induced, remediation-induced, or both?                                   |

### Techniques deliberately not mapped

- Bank-side phishing is not mapped because there is no scenario evidence that a bank employee was phished.
- Bank endpoint compromise and internal lateral movement are not mapped because no bank-side host compromise is confirmed.

- Ransomware, data encryption, destructive wiping, and extortion are not mapped because they are not represented in the scenario facts.
- Broad denial-of-service techniques are not mapped unless tied to the explicit service stop behavior affecting the vendor scheduler.
- Attribution to a named threat actor is not included because the exercise does not require attribution to make containment or recovery decisions.

### ATT&CK interpretation note

The original exercise correctly centered on software supply-chain compromise and trusted relationship risk. This revised version retains those anchors but adds explicit execution, persistence, credential-access, C2, exfiltration, and impact facts so the ATT&CK mapping is useful for technical validation rather than speculative categorization.

## 18. Source-to-Scenario Traceability

The exercise is derived from the uploaded source TTX describing a banking organization dependent on a third-party core servicing provider, an attack pattern involving compromise of a third-party software update channel, disruption of a core servicing platform, bank-side isolation, manual customer servicing fallback, reconnection decision-making, and after-action obligations.

| Source element                       | Revised scenario representation                                                                                                                                                                            | Enhancement added                                                                                      |
|--------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------|
| Third-party core servicing provider  | CoreServ SaaS supports branch/contact-center account servicing, loan servicing, hardship, and payment-arrangement workflows.                                                                               | Added architecture, integration gateway, SSO, API, managed file transfer, and logging sources.         |
| Software update-channel compromise   | Vendor CI/CD token misuse promotes a signed malicious hotfix into customer tenant namespaces.                                                                                                              | Added update version, CI/CD token, signing process, container deployment, and vendor evidence package. |
| Vendor-originated service disruption | Malicious payload stops a servicing scheduler, creating account-servicing API failures and backlog.                                                                                                        | Connected technical impact mechanics to operational consequences.                                      |
| Temporary disconnection              | SOC isolates vendor API routes, pauses file exchange, suspends OAuth client credential, and starts telemetry review.                                                                                       | Clarified SOC authority and credential/certificate containment, not just network disconnection.        |
| Manual servicing fallback            | Operations activates priority-tier manual servicing with maker-checker controls and backlog metrics.                                                                                                       | Added control overlays, customer harm categories, and exception routing.                               |
| Safe reconnection decision           | Joint SOC, application, business, and executive sign-off based on vendor evidence, bank telemetry, token rotation, and staged restoration.                                                                 | Added explicit reconnection checklist and residual risk record.                                        |
| MITRE mapping                        | Evidence-backed mapping to supply-chain, trusted relationship, valid accounts, shell execution, container job persistence, container discovery, token theft/use, HTTPS C2, exfiltration, and service stop. | Removed speculative techniques and tied each mapping to scenario facts.                                |

### Evaluation recommendations explicitly integrated

- Realism: Added integration paths, authentication methods, service accounts, update distribution mechanics, affected business services, and concrete bank-side artifacts.
- Cyber accuracy and ATT&CK: Defined the adversary path and mapped only techniques with explicit scenario evidence.
- Training value: Added technical hypotheses, evidence cards, decision gates, and validation questions to force more than process-level answers.
- Coherence: Preserved the original four-inject progression while adding hard evidence at each transition.
- Governance accuracy: Separated SOC technical authority from crisis-cell business and risk authority.
- Facilitation quality: Expanded discussion questions, expected actions, facilitator notes, prompt bank, reconnection criteria, and success criteria.

## 19. Optional Layout / Visual Suggestions and Glossary

### Visual suggestions for delivery version

- Cover page with scenario title, subtitle, duration, audience, and confidentiality marking.
- One-page architecture diagram showing bank users, integration gateway, IAM/vault, vendor SaaS tenant, CI/CD pipeline, and logging sources.
- Timeline page with four injects and decision gates: classify, isolate, reconnect, restore.
- Color-coded evidence cards for vendor statements, bank telemetry, operations impact, and legal/compliance considerations.
- Reconnection checklist as a one-page handout for executives and technical leads.
- Final appendix containing ATT&CK mapping and an improvement tracker.

### Acronyms and terms

| Term       | Meaning in this exercise                                                                                |
|------------|---------------------------------------------------------------------------------------------------------|
| API        | Application Programming Interface used for bank-to-vendor integration.                                  |
| C2         | Command-and-control communication between malicious code and adversary-controlled infrastructure.       |
| CI/CD      | Continuous integration/continuous deployment pipeline used by the vendor to build and release software. |
| CronJob    | A Kubernetes scheduled job that can run a containerized task on a defined schedule.                     |
| EDR        | Endpoint Detection and Response telemetry from workstations or servers.                                 |
| IdP / SSO  | Identity provider and single sign-on used for user authentication to the vendor portal.                 |
| IOC        | Indicator of compromise, such as a hash, IP address, domain, file name, object name, or log pattern.    |
| mTLS       | Mutual TLS authentication using certificates to validate both sides of a connection.                    |
| OAuth2     | Authorization framework used here for scoped API client credentials and access tokens.                  |
| P1 / Sev 2 | Example operational and cyber severity labels; replace with local severity nomenclature.                |
| SIEM       | Security Information and Event Management platform for log correlation and detection.                   |
| Tenant     | A logically separated customer environment within the vendor's multi-tenant SaaS platform.              |

#### End of exercise package

Facilitators should tailor vendor names, technical system names, severity labels, jurisdictional regulatory references, and communication approval paths before live delivery. Do not disclose facilitator-only attack-chain facts until the appropriate inject.